

Analyse des Vulnérabilités sur les Systèmes d'Exploitation

Objectifs :

- Identifier les failles communes sur Windows et Linux (services non sécurisés, ports ouverts, défauts de configuration et failles applicatives).
- Maîtriser le fonctionnement des scanners de vulnérabilités (Nessus, OpenVAS / Greenbone Community Edition, Nmap NSE).
- Savoir configurer et distinguer un scan réseau non authentifié d'un scan d'audit authentifié (identifiants Windows et Linux).
- Interpréter un rapport d'audit (score CVSS, détection des faux positifs et rétroportage) pour prioriser les remédiations de durcissement.

1. Typologie des Vulnérabilités et Détection Réseau

Avant d'exécuter un scanner lourd, l'auditeur cartographie la cible. Les faiblesses d'un système se classent en trois familles majeures.

Typologie des Faiblesses		
1. Failles logicielles	Dépassement de tampon, RCE, LPE (CVE)	
2. Défauts de réglage	Mots de passe faibles, partages ouverts	
3. Protocoles obsolètes	Données en clair (Telnet, HTTP, SMBv1, FTP)	

1.1 Prise d'empreinte et identification des bannières (*Banner Grabbing*)

Le scanner commence par interroger les ports ouverts pour forcer le service à révéler son nom et sa version logicielle exacte.

Commandes d'inspection manuelle rapide des bannières :

- **Détection de version via Netcat :**
nc -vn <IP_Cible> 22
nc -vn <IP_Cible> 80
- **Inspection fine des en-têtes HTTP/HTTPS :**
curl -k -I http://<IP_Cible>
curl -k -I https://<IP_Cible>
- **Vérification du certificat et de la négociation SSL/TLS :**
openssl s_client -connect <IP_Cible>:443 -brief

2. Détection Rapide avec Nmap et le Moteur NSE

Avant de lancer un scan complet Nessus ou OpenVAS (qui peut durer plusieurs dizaines de minutes), **Nmap** permet d'identifier immédiatement les failles critiques grâce aux scripts NSE (*Nmap Scripting Engine*).

2.1 Détection globale des services et OS

Pour obtenir l'empreinte logicielle complète d'un serveur distant :

```
nmap -sS -sV -O -T4 -p- <IP_Cible>
```

- -sS : scan TCP SYN furtif et rapide.
- -sV : détection active de version des bannières.
- -O : identification probabiliste du système d'exploitation.
- -p- : scan de l'intégralité des 65 535 ports TCP (indispensable pour ne rater aucun service masqué).

2.2 Détection automatisée de vulnérabilités via Nmap

Nmap intègre des bases de vulnérabilités exploitables directement depuis la ligne de commande :

- **Lancer l'ensemble des scripts de vulnérabilités connus :**
nmap -sV --script vuln <IP_Cible>
- **Vérifier spécifiquement les failles critiques SMB / Windows :**
nmap -p 445 --script smb-vuln* <IP_Cible>
- **Détecter les faiblesses de configuration SSL/TLS :**
nmap -p 443 --script ssl-enum-ciphers <IP_Cible>

3. Métrique et Priorisation : Le Système CVSS

Le standard universel **CVSS** (*Common Vulnerability Scoring System*) fournit une note objective de **0.0 à 10.0** pour chaque faille répertoriée.

3.1 Grille de sévérité CVSS v3.1

Sévérité	Intervalle	Impact type	Action requise
Critique (Critical)	9.0 – 10.0	RCE à distance, sans mot de passe, contournement total d'authentification	Traitement immédiat en urgence
Élevé (High)	7.0 – 8.9	Élévation locale de privilèges (root/SYSTEM), vol d'identifiants	Correction sous quelques jours
Moyen (Medium)	4.0 – 6.9	Fuite de données partielle, DoS nécessitant des prérequis	Correction planifiée
Faible (Low)	0.1 – 3.9	Fuite d'informations mineure, contournement difficile	Durcissement de fond
Info (None)	0.0	Découverte d'un port ouvert ou d'une bannière informative	Simple archivage / inventaire

3.2 Vecteur d'attaque (*Attack Vector* - AV)

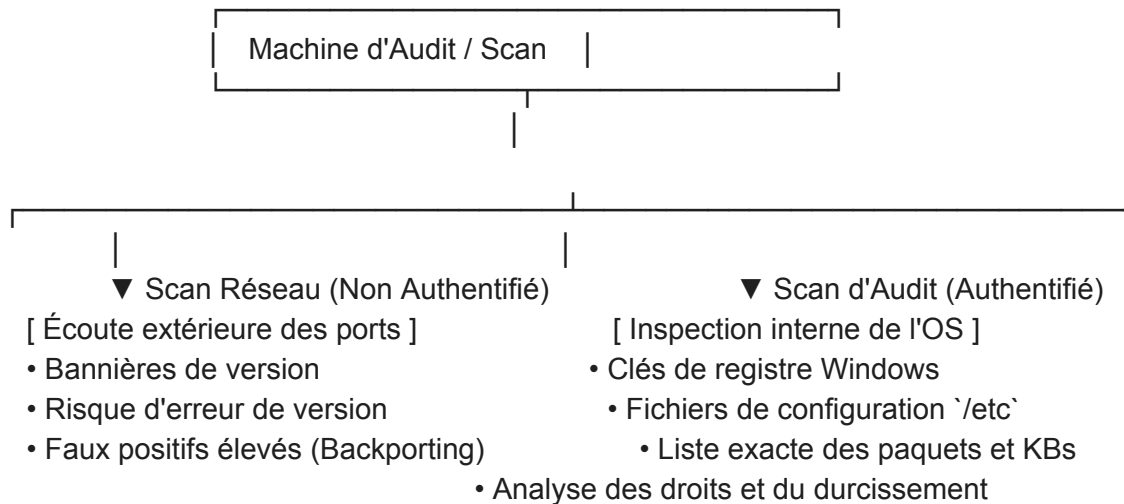
Le vecteur précise où doit se situer l'attaquant pour exploiter la faille :

- **AV:N (Network)** : Exploitable directement par Internet ou le réseau local, sans compte.
- **AV:A (Adjacent)** : Nécessite d'être sur le même domaine de diffusion (ex: attaques ARP, LLMNR).
- **AV:L (Local)** : Nécessite une session interactive ou un compte utilisateur déjà existant sur l'OS.

- **AV:P (Physical)** : Nécessite d'accéder physiquement au boîtier ou au support de stockage.

4. Scan Non Authentifié vs Scan Authentifié

La fiabilité de l'audit dépend directement du niveau d'accès accordé au scanner.



4.1 Préparation d'une cible Linux pour le Scan Authentifié

Pour auditer un serveur Linux, le scanner se connecte en SSH avec un compte disposant de droits d'inspection.

1. **Création d'un compte de scan d'audit dédié sur la cible Linux :**

```
sudo useradd -m -s /bin/bash auditscan
```

```
sudo passwd auditscan
```
2. **Autoriser l'élévation sudo sans saisie de mot de passe (option recommandée par Nessus/OpenVAS) :**

```
echo "auditscan ALL=(ALL) NOPASSWD: ALL" | sudo tee /etc/sudoers.d/auditscan
```

```
sudo chmod 440 /etc/sudoers.d/auditscan
```
3. **Tester la connexion SSH depuis la machine d'audit :**

```
ssh auditscan@<IP_Linux> "sudo uname -a"
```

4.2 Préparation d'une cible Windows pour le Scan Authentifié

Pour auditer un serveur Windows, le scanner communique via SMB (port 445) et WinRM (ports 5985/5986) ou WMI (port 135).

1. **Vérifier et démarrer le service WinRM sur la cible Windows (PowerShell Administrateur) :**

```
Get-Service WinRM  
Enable-PSRemoting -Force
```

2. **Vérifier l'ouverture des ports locaux dans le pare-feu :**

```
Get-NetFirewallRule -DisplayGroup "Windows Remote Management" | Select-Object  
DisplayName, Enabled, Direction
```

3. **Valider la communication depuis la machine d'audit (ou poste d'admin) :**

```
Test-WSMan -ComputerName <IP_Windows>  
Test-NetConnection -ComputerName <IP_Windows> -Port 445
```

5. Déploiement et Utilisation des Scanners Lourds

5.1 OpenVAS / Greenbone Community Edition (GVM)

OpenVAS est la solution open-source de référence pour la gestion des vulnérabilités.

Commandes de diagnostic et de gestion du service :

- **Vérifier l'intégrité de l'installation et des flux NVT :**
`gvm-check-setup`
- **Démarrer l'ensemble des démons (scanner, manager, interface web) :**
`gvm-start`
- **Changer le mot de passe du compte administrateur web (admin) :**
`gvmc --user=admin --new-password="MonSuperMotDePasse123!"`
- **Accès à l'interface web :** Ouvrir un navigateur sur `https://<IP_Machine_Audit>:9392`.

5.2 Nessus Essentials (Tenable)

Nessus s'appuie sur des plugins NASL mis à jour quotidiennement.

Commandes de contrôle du service Nessus :

- **Vérifier le statut du service sous Linux :**
`systemctl status nessusd`
- **Démarrer ou relancer le service Nessus :**
`sudo systemctl restart nessusd`
- **Accès à l'interface d'administration :** Ouvrir un navigateur sur `https://<IP_Machine_Audit>:8834`.

6. Traitement des Faux Positifs et Remédiations Immédiates

6.1 Le piège du Backporting (Rétroportage)

Sur les distributions stables comme Debian, Ubuntu ou Red Hat/Rocky, les mainteneurs de paquets ne changent pas le numéro de version majeure du logiciel pour ne pas casser la production. Ils intègrent le correctif de sécurité directement sur la version existante.

- **Le problème** : Un scan externe voit Apache 2.4.52 et alerte sur une CVE corrigée dans la 2.4.54.
- **La vérification locale** : Il faut consulter le journal des correctifs officiels du paquet :
`apt-get changelog apache2 | grep -i "CVE-2023-"`

Si la CVE apparaît avec mention de correction, il s'agit d'un **faux positif** du scanner réseau.

6.2 Application des remédiations directes (Défense en profondeur)

Cas 1 : Désactivation d'un service superflu (Réduction de surface)

- **Sous Linux (exemple pour CUPS / impression) :**
`sudo systemctl stop cups cups-browsed`
`sudo systemctl disable cups cups-browsed`
`sudo systemctl mask cups`
- **Sous Windows (exemple pour le Spouleur d'impression) :**
`Stop-Service -Name Spooler -Force`
`Set-Service -Name Spooler -StartupType Disabled`

Cas 2 : Blocage immédiat du port via le pare-feu local

- **Sous Linux (ufw) :**
`sudo ufw default deny incoming`
`sudo ufw default allow outgoing`
`sudo ufw allow from 192.168.1.0/24 to any port 22 proto tcp`
`sudo ufw enable`
- **Sous Windows (PowerShell) :**
Bloquer le port RDP (3389) pour toutes les IP sauf le sous-réseau d'administration
`New-NetFirewallRule -DisplayName "Restreindre RDP Admin" -Direction Inbound`
`-LocalPort 3389 -Protocol TCP -Action Allow -RemoteAddress "192.168.1.50"`

7. Commandes Complémentaires et Boîte à Outils

Ce mémento rassemble les commandes utiles pour inspecter, tester et valider l'état du système pendant les travaux pratiques.

7.1 Diagnostic rapide du réseau et des ports locaux

- **Lister les processus écoutant sur le réseau sous Linux :**
`ss -tulpn | grep LISTEN`
- **Identifier le chemin d'un exécutable rattaché à un port sous Linux :**
`ls -la /proc/$(ss -tulpn | grep ':80 ' | awk '{print $NF}' | cut -d',' -f2 | cut -d'=' -f2)/exe`
- **Lister les ports ouverts avec processus sous Windows (PowerShell) :**
`Get-NetTCPConnection -State Listen | Select-Object LocalAddress, LocalPort, OwningProcess, @{Name="ProcessName";Expression={{(Get-Process -Id $_.OwningProcess).ProcessName}} | Sort-Object LocalPort`

7.2 Scripts Nmap ciblés sur les services standards

- **Audit du serveur Web (HTTP/HTTPS) :**
`nmap -p 80,443 --script http-methods,http-title,http-enum <IP_Cible>`
- **Audit du serveur SSH :**
`nmap -p 22 --script ssh2-enum-algos <IP_Cible>`
- **Audit des protocoles de résolution de noms Windows (NetBIOS / SMB) :**
`nmap -sU -sS -p U:137,T:139,T:445 --script smb-os-discovery,smb-security-mode <IP_Cible>`

7.3 Audit de conformité des paquets et correctifs en local

- **Lister les mises à jour de sécurité en attente sur Debian/Ubuntu :**
`apt update && apt list --upgradable | grep -i security`
- **Lister l'historique des correctifs KB installés sur Windows Server :**
`Get-HotFix | Sort-Object InstalledOn -Descending | Select-Object -First 10 HotFixID, Description, InstalledOn`
- **Rechercher si un correctif spécifique est présent sur Windows (exemple KB5004945) :**
`Get-HotFix -Id KB5004945`